

UNIVERSIDAD RAFAEL LANDÍVAR

ÁREA DE INGENIERÍA

Programación Web



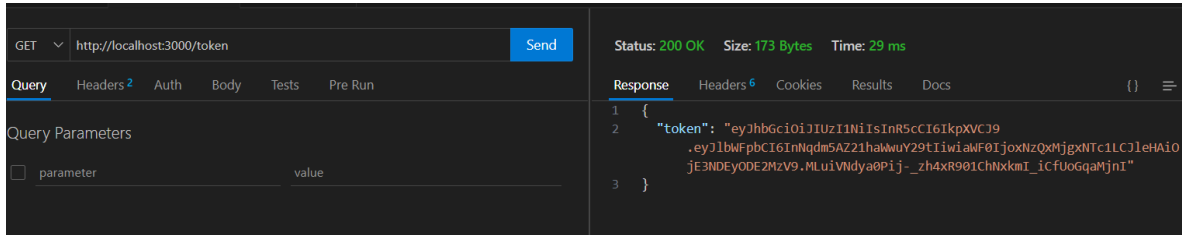
ACTIVIDAD

Json Web Token

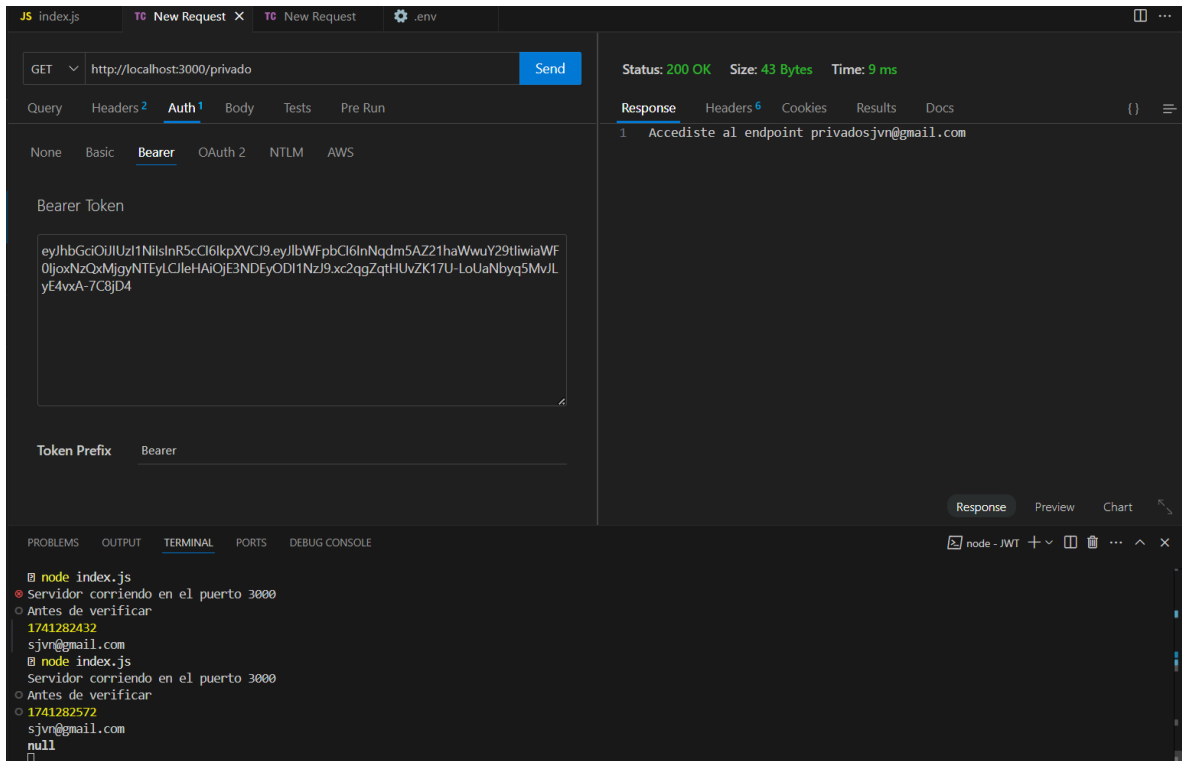
AUTOR

Sajvin Gómez, Mario Daniel (1612921)

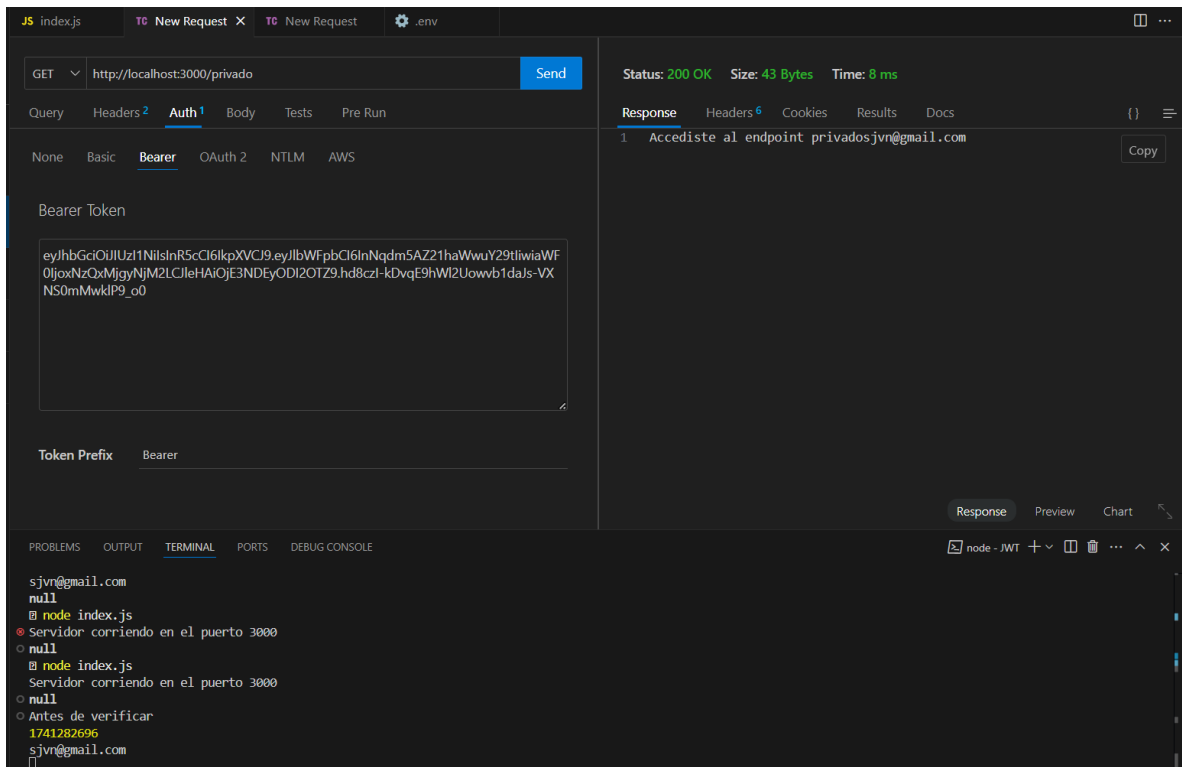
Generar un JWT con una clave secreta y una carga útil personalizada.



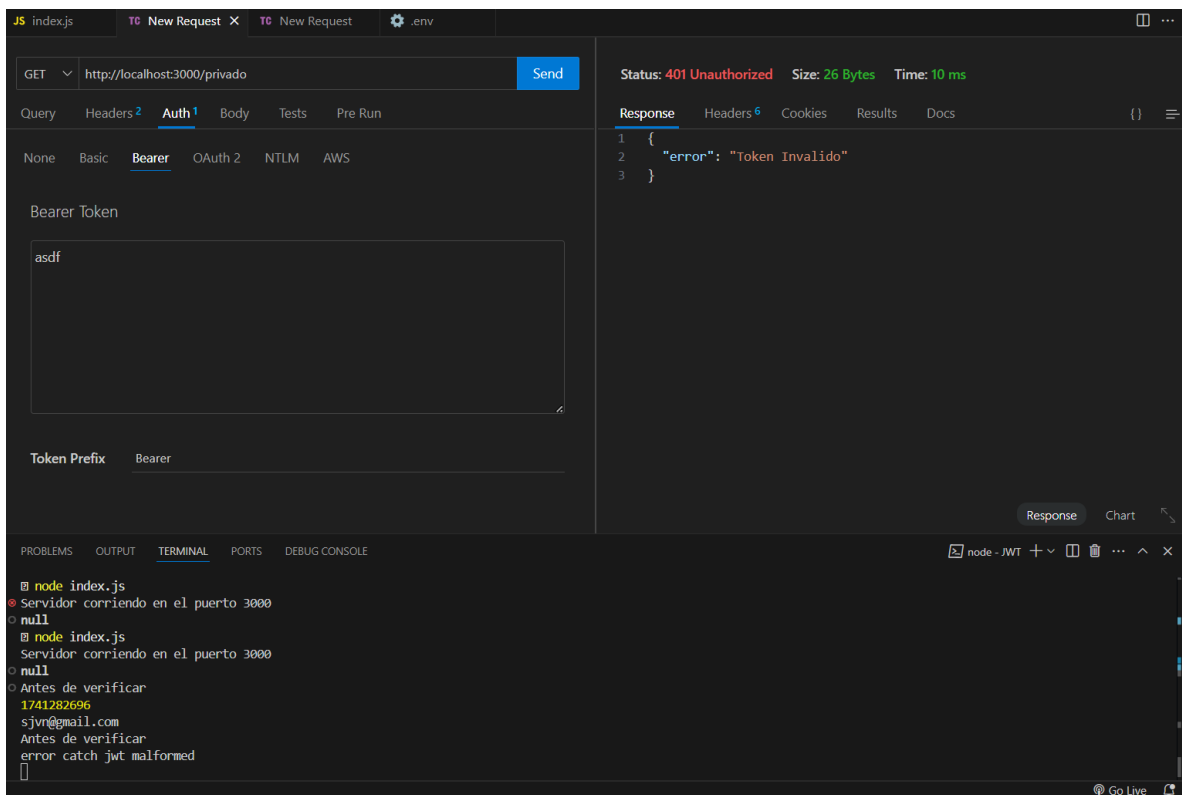
Decodificar un JWT sin validarlo para extraer su contenido.



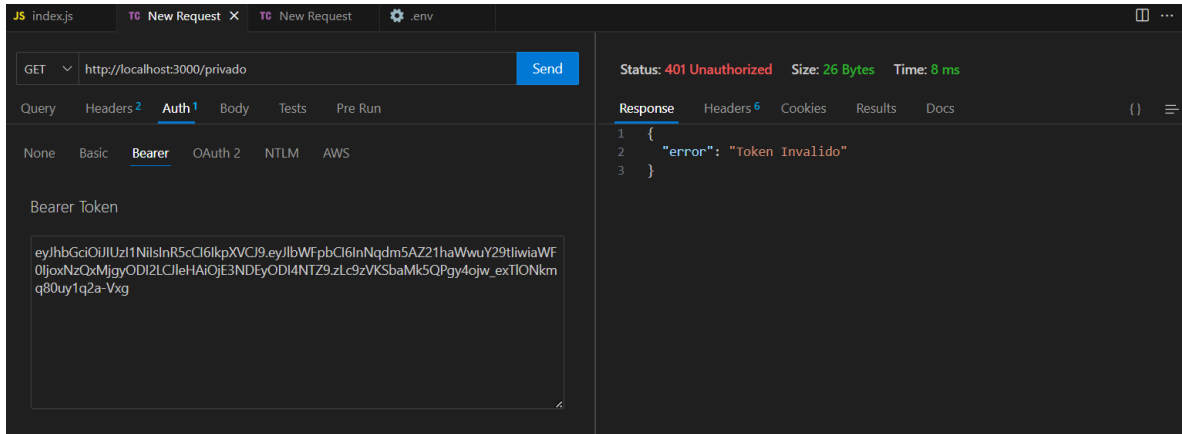
Verificar la firma de un JWT usando la clave secreta correcta.



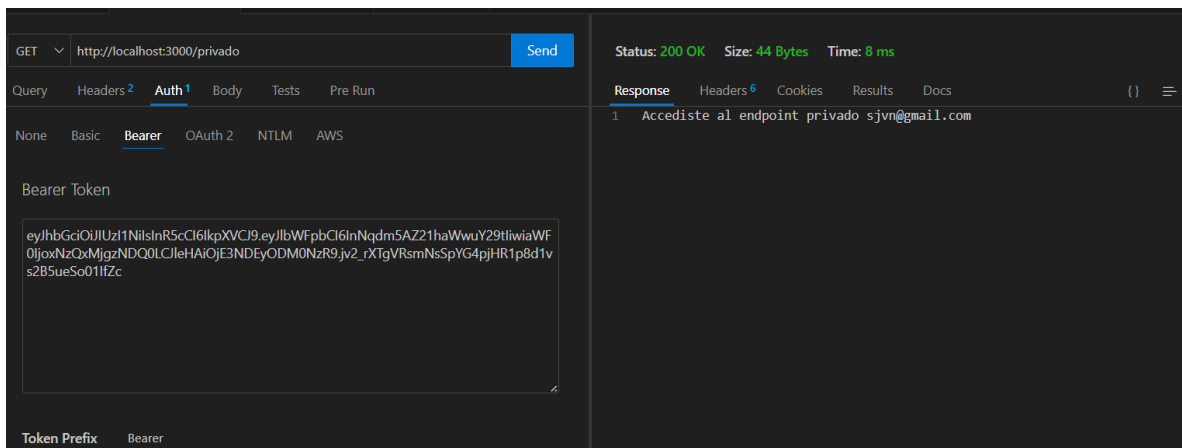
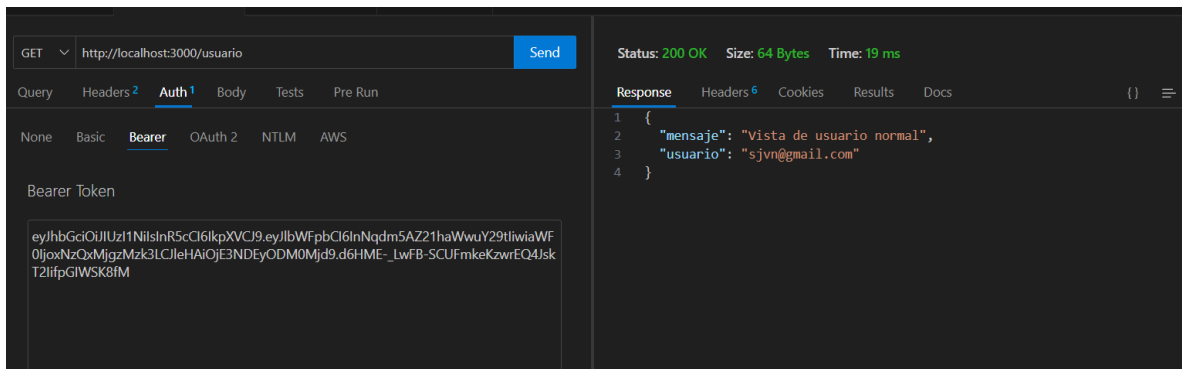
Intentar verificar un JWT con una clave secreta incorrecta y manejar el error



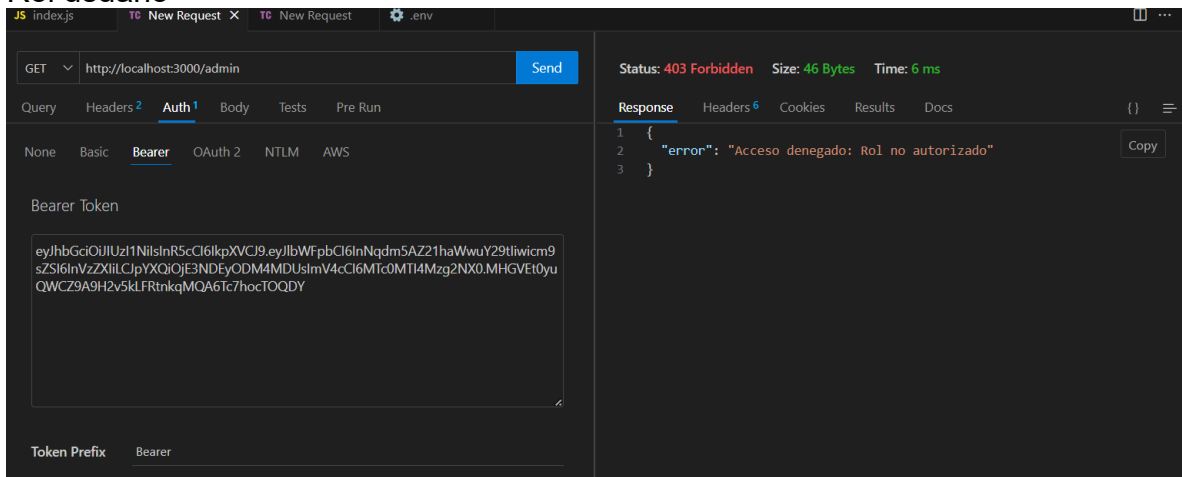
Generar un JWT con expiración de 30 segundos y probar qué sucede después de su vencimiento.



Implementar una función en Express.js que valide JWT en rutas protegidas para reutilizarla en varias rutas.



Rol admin



Código

```
const express = require("express");
require("dotenv").config();
const jwt = require("jsonwebtoken");

const secret = process.env.KEY;

const app = express();

app.use(express.json());

// Middleware para validar el JWT y verificar el rol
function validarTokenYRol(rolesPermitidos) {
  return (req, res, next) => {
    const token = req.header("Authorization")?.split(" ")[1];
    if (!token) return res.status(401).json({ error: "Acceso denegado" });

    try {
      console.log("Antes de verificar");
      const decoded = jwt.verify(token, secret);
      console.log(decoded.exp);
      if (decoded.exp < Math.floor(Date.now() / 1000)) {
        console.log("Ya expiró", decoded.exp);
        return res.status(401).json({ error: "Token expirado" });
      }

      // Verificar si el rol del usuario está permitido
      if (!rolesPermitidos.includes(decoded.role)) {
        return res.status(403).json({ error: "Acceso denegado: Rol no autorizado" });
      }

      req.user = decoded;
      console.log(decoded.email);
      next(); // Si el token es válido y el rol es correcto, continuamos con
la ejecución de la ruta
    } catch (error) {
      console.log("error catch", error.message);
      res.status(401).json({ error: "Token inválido" });
    }
  };
}

app.get("/token", (req, res) => {
```

```
const token = jwt.sign(
  { email: "sjvn@gmail.com", role: "user" }, //
  secret,
  { expiresIn: "1m" }
);
console.log(jwt.decode(token));
res.json({ token });
});

// Ruta protegida, solo accesible por admin
app.get("/privado", validarTokenYRol(["admin", "user"]), (req, res) => {
  res.send("Accediste al endpoint privado " + req.user.email);
});

// Ruta protegida, solo accesible por admin
app.get("/usuario", validarTokenYRol(["admin", "user"]), (req, res) => {
  res.json({ mensaje: "Vista de usuario normal", usuario: req.user.email });
});

// Ruta restringida solo a admin
app.get("/admin", validarTokenYRol(["admin"]), (req, res) => {
  res.send("Accediste al endpoint de admin " + req.user.email);
});

app.listen(3000, () => {
  console.log("Servidor corriendo en el puerto 3000");
});
```